

Artigo final de sistemas distribuídos - Análise do Protocolo Kerberos: Autenticação e Segurança em Sistemas Distribuídos

Luiz Antônio Lima de Freitas Leite¹, Max José Lobato Pantoja Junior¹,
Wesley Pontes Barbosa¹, Luiz Sérgio Samico Maciel¹

¹Instituto de Ciências Exatas e Naturais (ICEN) – Universidade Federal Pará
Belém, PA – Brasil

{luiz.freitas.leite,max.junior,wesley.pontes.barbosa,luiz.filho}@icen.ufpa.br

Abstract. *This article presents a study on digital security techniques in distributed systems, focusing on the Kerberos protocol. It explores the concepts of authentication, trusted third parties, and symmetric cryptography. Furthermore, a case study on its implementation in directory services (Active Directory) is presented, demonstrating its effectiveness in mitigating network threats.*

Resumo. *Este artigo apresenta um estudo sobre técnicas de segurança digital em sistemas distribuídos, com foco no protocolo Kerberos. São explorados os conceitos de autenticação, terceira parte confiável e criptografia simétrica. Além disso, é apresentado um estudo de caso sobre sua implementação em serviços de diretório (Active Directory), demonstrando sua eficácia na mitigação de ameaças em rede.*

1. Introdução

A segurança da informação compõe um dos pilares fundamentais no projeto e implementação de Sistemas Distribuídos. Segundo Tanenbaum e Van Steen [Tanenbaum and Van Steen 2017], a abertura e a conectividade inerentes a esses sistemas, embora permitam o compartilhamento eficiente de recursos, introduzem vulnerabilidades críticas inexistentes em sistemas centralizados. Enquanto um sistema operacional local detém controle total sobre o acesso à memória e aos periféricos, os sistemas distribuídos dependem de redes de comunicação para a troca de mensagens. Frequentemente, essas redes comportam-se como canais inseguros, suscetíveis à interceptação passiva (*sniffing*) e à modificação ativa ou mascaramento (*spoofing*) de dados por agentes mal-intencionados.

O cerne dessa problemática reside na **autenticação**: a necessidade de um cliente provar sua identidade a um servidor remoto sem a exposição de sua senha em texto claro pela rede. O tráfego de credenciais por meios inseguros, ainda que ocorra de forma esporádica, vulnerabiliza o sistema a ataques de captura de tráfego. Adicionalmente, em cenários compostos por múltiplos serviços, como sistemas de arquivos e bancos de dados, a exigência de repetidas inserções de senhas degrada a usabilidade e induz o usuário a adotar práticas de segurança frágeis.

Neste cenário, o protocolo **Kerberos** consolida-se como uma solução padrão para autenticação em redes inseguras. Desenvolvido originalmente no Projeto Athena do MIT [Neuman and Ts'o 1994], o protocolo fundamenta-se no uso de criptografia simétrica e na existência de uma Terceira Parte Confiável (Trusted Third Party - TTP) para mediar

a confiança entre clientes e servidores. O Kerberos permite que entidades comprovem sua identidade mutuamente, garantindo a integridade e a confidencialidade das sessões estabelecidas.

Este artigo tem como objetivo analisar a arquitetura de segurança do protocolo Kerberos. Serão detalhados os conceitos fundamentais de criptografia e canais seguros, o fluxo de troca de mensagens para obtenção de tickets e a mitigação de ataques de repetição. Por fim, apresenta-se um estudo de caso sobre sua implementação no Microsoft Active Directory, demonstrando sua aplicabilidade em infraestruturas modernas.

2. Conceitos de Segurança em Sistemas Distribuídos

Para compreender o funcionamento e as decisões de projeto do Kerberos, é imperativo estabelecer os fundamentos sobre canais seguros e os modelos de confiança em redes distribuídas. A segurança nestes sistemas depende da capacidade de transformar um canal de comunicação inseguro em um canal seguro através de mecanismos criptográficos.

2.1. Canais Seguros e Criptografia

Um canal seguro é um meio de comunicação que garante propriedades essenciais de segurança, nomeadamente: a **confidencialidade**, assegurando que apenas as partes autorizadas tenham acesso à informação; a **integridade**, garantindo que a mensagem não foi alterada em trânsito; e a **autenticação**, que confirma a identidade das partes envolvidas [Coulouris et al. 2013].

Para implementar tais canais, utilizam-se algoritmos criptográficos divididos em duas categorias principais:

- Criptografia assimétrica (Chave Pública): utiliza um par de chaves (pública e privada). Embora resolva problemas de distribuição de chaves e assinatura digital, possui alto custo computacional, sendo centenas de vezes mais lenta que a criptografia simétrica.
- Criptografia simétrica (Chave Secreta): utiliza uma única chave compartilhada entre as partes para cifrar e decifrar as mensagens (ex: AES, DES). Devido ao seu alto desempenho, é a escolha ideal para cifrar o fluxo de dados em sessões de comunicação longas.

O protocolo Kerberos baseia-se primordialmente na criptografia simétrica para garantir velocidade no processamento de milhares de autenticações simultâneas. No entanto, o uso exclusivo de chaves simétricas introduz um desafio logístico crítico: a distribuição segura dessas chaves.

2.2. Autenticação e Terceira Parte Confiável (TTP)

Em um sistema distribuído de larga escala com N entidades (usuários e servidores), se cada par de entidades precisasse se comunicar diretamente com segurança, seriam necessárias $N(N - 1)/2$ chaves secretas distintas. O gerenciamento descentralizado dessas chaves torna-se inviável à medida que o sistema cresce.

Para mitigar esse problema de complexidade quadrática, adota-se o modelo de Terceira Parte Confiável (*Trusted Third Party* – TTP). Neste modelo, introduz-se uma autoridade central na qual todos os participantes confiam, denominada Centro de Distribuição de Chaves (*Key Distribution Center* – KDC).

Em vez de o cliente provar sua identidade diretamente para cada servidor de arquivos ou impressão, ele prova sua identidade uma única vez para o KDC. A autoridade central, então, emite credenciais temporárias (tickets) cifradas, que o cliente apresenta aos servidores de destino. Essa arquitetura centraliza a administração de segurança, minimiza a exposição de segredos de longa duração (senhas) e permite a escalabilidade do sistema, visto que cada nova entidade precisa estabelecer uma chave secreta apenas com o KDC, e não com todos os outros participantes da rede.

3. O Protocolo Kerberos

O Kerberos é um protocolo de autenticação de rede projetado para fornecer autenticação forte para aplicações cliente/servidor usando criptografia de chave secreta. A versão 5 (V5), definida na RFC 4120, é o padrão atual da indústria e resolve o problema de transmitir identidades através de uma rede insegura sem expor senhas.

3.1. Origem e Significado

O nome do protocolo é uma referência direta à mitologia grega: Cérbero (*Kerberos*), o cão de três cabeças que guardava os portões do submundo (Hades). A analogia reflete a arquitetura de confiança de três pontas do protocolo, onde as "cabeças" representam o Cliente, o Servidor e o KDC (Key Distribution Center), que juntos vigiam o acesso à rede.

Historicamente, o protocolo foi desenvolvido no MIT (*Massachusetts Institute of Technology*) em meados da década de 1980 como parte do **Projeto Athena**. O objetivo era criar um ambiente educacional distribuído onde estudantes pudessem acessar seus arquivos de qualquer estação de trabalho sem comprometer a segurança da rede. Baseado nas propostas teóricas de Needham e Schroeder, o Kerberos foi a solução encontrada para impedir que senhas trafegassem em texto claro, prevenindo ataques de interceptação (*sniffing*) [Neuman and Ts'o 1994].

3.2. Arquitetura e Componentes

O ecossistema Kerberos opera baseando-se em tickets e é composto pelas três entidades lógicas mencionadas na analogia mitológica:

- **Cliente (Principal):** A entidade (usuário ou software) que deseja acessar um recurso. Cada cliente possui uma chave secreta K_c , geralmente derivada do hash de sua senha.
- **Servidor de Aplicação (SS - Service Server):** O recurso que o cliente deseja acessar (ex: servidor de arquivos, banco de dados). O servidor compartilha uma chave secreta K_s exclusivamente com o KDC.
- **KDC (Key Distribution Center):** A terceira parte confiável (*Trusted Third Party*). O KDC mantém um banco de dados com as chaves secretas de todos os usuários e serviços. Logicamente, ele é dividido em dois subcomponentes funcionais:
 - *Authentication Server (AS):* Responsável pelo login inicial. Ele verifica a senha do usuário e emite o Ticket de Concessão de Tickets (TGT).
 - *Ticket Granting Server (TGS):* Responsável por emitir tickets de serviço específicos para clientes que já possuem um TGT válido, viabilizando o recurso de *Single Sign-On*.

3.3. Fluxo de Mensagens e Chaves de Sessão

O funcionamento do Kerberos pode ser dividido em três fases distintas: a autenticação inicial, a obtenção de autorização para serviços e o acesso ao recurso. A Figura 1 ilustra a troca de mensagens entre as entidades.

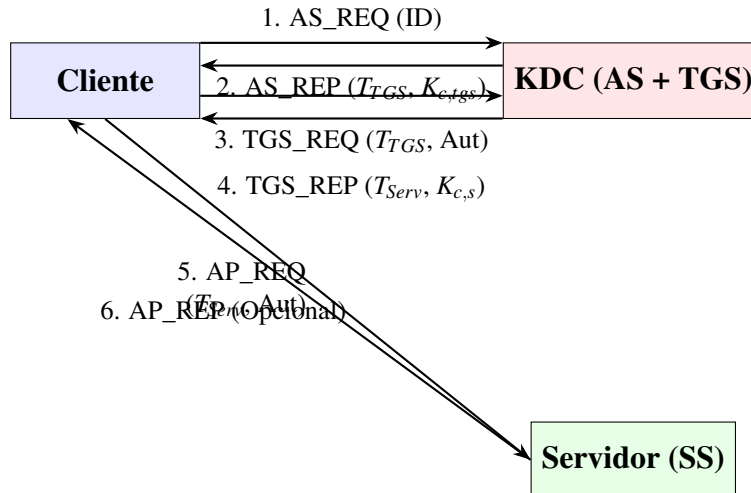


Figura 1. Fluxo simplificado de mensagens do protocolo Kerberos.

O detalhamento das etapas descritas na Figura 1 segue abaixo, destacando o uso das chaves criptográficas:

1. **Autenticação Inicial (AS):** O cliente envia uma solicitação em texto claro contendo seu ID para o AS. O AS verifica se o usuário existe em seu banco de dados.
2. **Emissão do TGT:** O AS gera uma chave de sessão temporária ($K_{c,tgs}$) para comunicação futura com o TGS. O AS responde com duas mensagens:
 - Mensagem A: Cifrada com a chave do usuário (K_c). Contém a chave de sessão $K_{c,tgs}$.
 - Mensagem B (TGT): Cifrada com a chave secreta do TGS (K_{TGS}). Contém o ID do cliente, validade e a chave de sessão $K_{c,tgs}$.

Nota: O cliente decifra a Mensagem A usando sua senha. Se a senha estiver correta, ele obtém a chave de sessão. O TGT permanece cifrado e opaco para o cliente.

3. **Solicitação de Serviço (TGS):** Para acessar um recurso (ex: servidor de arquivos), o cliente envia ao TGS o TGT (obtido no passo anterior) e um *Autenticador* (cifrado com $K_{c,tgs}$ contendo ID e Timestamp).
4. **Emissão do Ticket de Serviço:** O TGS decifra o TGT com sua chave privada, recupera $K_{c,tgs}$ e usa essa chave para decifrar o Autenticador. Se validado, o TGS gera uma nova chave de sessão para o serviço específico ($K_{c,s}$) e envia um Ticket de Serviço cifrado com a chave do Servidor de Aplicação (K_s).
5. **Acesso ao Recurso:** O cliente envia o Ticket de Serviço e um novo Autenticador ao Servidor de Aplicação. O servidor usa sua chave K_s para abrir o ticket, obter a chave de sessão $K_{c,s}$ e validar o usuário [Tanenbaum and Van Steen 2017].

3.4. Mitigação de Ataques e Robustez do Protocolo

A arquitetura do Kerberos foi projetada sob o pressuposto de que a rede é inerentemente insegura, onde pacotes podem ser interceptados, modificados ou injetados. Para garantir a segurança, o protocolo utiliza uma combinação de segredos compartilhados, criptografia simétrica e uma Terceira Parte Confiável (TTP) [Coulouris et al. 2013].

A Tabela 1 detalha como os principais componentes do protocolo atuam na defesa contra ameaças comuns:

Tabela 1. Mecanismos de Segurança e Ameaças Mitigadas

Mecanismo	Defesa e Funcionamento
Timestamps	Impede o <i>Replay Attack</i> . O servidor de aplicação verifica se o horário no autenticador está dentro da janela de sincronização permitida em relação ao seu relógio local [Neuman and Ts'o 1994].
Authenticators	Provam que o cliente possui a chave de sessão em tempo real. Como são válidos apenas para uma única solicitação, sua interceptação torna-se inútil para uso posterior.
Autenticação Mútua	Opcionalmente, o servidor pode provar sua identidade ao cliente decifrando o timestamp enviado e reenviando-o (incrementado), o que mitiga ataques de <i>Server Spoofing</i> .
Pre-Authentication	Exige que o cliente cifre um timestamp com sua senha antes do AS emitir o TGT. Isso dificulta ataques de dicionário <i>offline</i> , pois o KDC não envia respostas cifradas para qualquer usuário arbitrário.

3.4.1. Autenticação e Pré-autenticação

O processo de autenticação inicial no ecossistema Kerberos estabelece o primeiro nível de confiança entre o usuário e a infraestrutura de rede e ocorre primordialmente através da comunicação direta com o Servidor de Autenticação. Durante esta fase, o objetivo principal reside na obtenção de uma credencial mestra, amplamente denominada como Ticket de Concessão de Tickets, que servirá como a base para todas as solicitações subsequentes de serviços na rede [Neuman and Ts'o 1994]. Esta etapa é crítica, pois é o único momento em que o sistema lida diretamente com a chave derivada da senha do usuário, o que exige mecanismos rigorosos para evitar o vazamento de informações.

Nas versões fundamentais do protocolo, o servidor respondia a qualquer pedido de login com uma mensagem cifrada pela chave do usuário, o que permitia que um atacante coletasse esses pacotes para realizar tentativas de decodificação exaustivas em ambientes externos. Para mitigar esta vulnerabilidade, as implementações contemporâneas utilizam o mecanismo de pré-autenticação, que obriga o cliente a provar o conhecimento de sua chave secreta antes mesmo que o Centro de Distribuição de Chaves emita qualquer resposta relevante. Na prática, o dispositivo do usuário cifra um carimbo de tempo atualizado com a chave derivada de sua senha e o envia como parte da requisição ini-

cial, o que permite ao servidor validar a identidade do solicitante de forma imediata [Tanenbaum and Van Steen 2017].

A adoção da pré-autenticação eleva consideravelmente a segurança do sistema, pois impede que um invasor obtenha amostras de texto cifrado para ataques de dicionário sem antes superar o desafio criptográfico inicial. Caso o Servidor de Autenticação consiga decifrar o carimbo de tempo enviado, ele confirma a legitimidade do pedido e prossegue com a emissão do ticket cifrado pela chave do Servidor de Concessão de Tickets, o que garante a integridade do fluxo de credenciais desde o primeiro contato com a autoridade central [Coulouris et al. 2013]. Este procedimento assegura que apenas usuários devidamente autenticados possam interagir com as camadas mais profundas do protocolo e preserva a robustez da rede contra tentativas de acesso não autorizado por meio de suposições de credenciais.

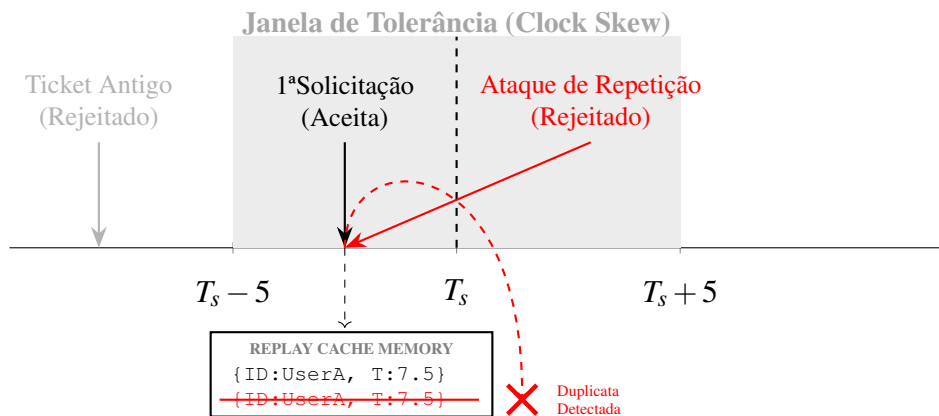
3.4.2. Prevenção contra Ataques de Repetição (*Replay*)

A eficácia do Kerberos contra o sequestro de sessões reside na volatilidade controlada do *Authenticator*. Diferente de um token estático, o autenticador é uma estrutura de dados de "uso único" que vincula a identidade do cliente ao exato momento da solicitação. Segundo Neuman e Ts'o [Neuman and Ts'o 1994], essa construção permite que o servidor de aplicação verifique a atualidade da requisição sem consultar o KDC em tempo real, o que preserva a escalabilidade do sistema.

O processo de detecção de repetição ocorre em um equilíbrio entre o *Clock Skew* e o *Replay Cache*. O servidor primeiro aplica um filtro temporal: se o *timestamp* cifrado na mensagem divergir do relógio do servidor além da margem de tolerância (geralmente 5 minutos), a mensagem é descartada por presunção de obsolescência ou tentativa de fraude. No entanto, se o atacante capturar e reenviar o pacote dentro deste intervalo de 5 minutos, o filtro temporal sozinho falharia. É aqui que entra o cache de repetição, que atua como uma memória de curto prazo do servidor. Para cada autenticador validado, o servidor armazena uma entrada contendo o nome do cliente, o serviço solicitado e o *timestamp*. Se uma nova solicitação apresentar dados idênticos aos contidos no cache, o servidor identifica a colisão e interrompe o acesso, tratando a conexão como uma duplicata maliciosa [Tanenbaum and Van Steen 2017].

Um aspecto crítico dessa implementação é que o cache não precisa crescer indefinidamente. Como qualquer mensagem com mais de 5 minutos é automaticamente rejeitada pelo filtro de *Clock Skew*, o servidor pode descartar registros do cache que superem essa idade. Essa simbiose garante proteção robusta com baixo custo computacional. Contudo, essa dependência torna o protocolo vulnerável a manipulações no serviço de tempo; se um invasor conseguir comprometer o servidor NTP (*Network Time Protocol*) da rede, ele poderia, teoricamente, "congelar" ou retroceder o tempo percebido pelos servidores, estendendo a validade de tickets capturados e viabilizando ataques de repetição que o cache já teria descartado [Coulouris et al. 2013].

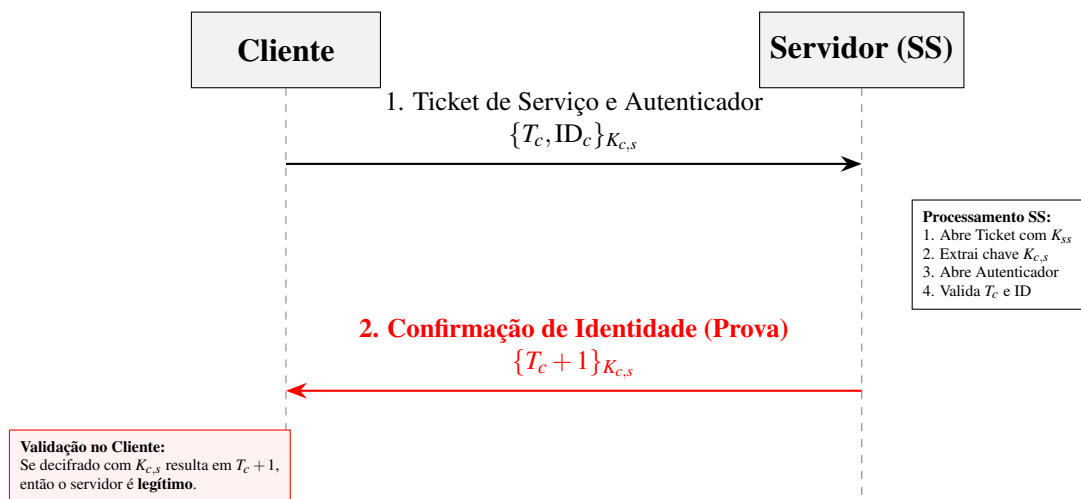
Mecanismo de Prevenção de Replay com Replay Cache



3.4.3. Autenticação Mútua e Confidencialidade

A autenticação mútua constitui um dos pilares mais significativos do protocolo Kerberos e assegura que o servidor também comprove sua identidade perante o cliente, o que previne que o usuário forneça dados sensíveis a um serviço impostor. Este processo depende inteiramente da chave de sessão, referenciada matematicamente como $K_{c,s}$, que consiste em um segredo temporário compartilhado exclusivamente entre o cliente, o servidor de destino e o Centro de Distribuição de Chaves [Neuman and Ts'o 1994]. Quando o servidor recebe o pedido de acesso, ele utiliza sua própria chave secreta para extrair a chave de sessão contida no ticket e, em seguida, cifra um carimbo de tempo modificado para retornar ao cliente. Esse retorno serve como uma evidência técnica da legitimidade do serviço, visto que apenas o servidor autêntico possui os meios criptográficos para acessar a chave de sessão necessária para tal resposta.

Fluxo de Autenticação Mútua



No que concerne à confidencialidade das informações, o sistema estabelece uma

separação rigorosa entre as chaves de longa duração, as quais são baseadas nas senhas dos usuários, e as chaves de sessão geradas para cada interação específica. Essa arquitetura garante que as senhas mestras nunca sejam transmitidas diretamente pela rede, o que as protege contra ataques de interceptação passiva. Além disso, a natureza efêmera das credenciais de serviço assegura que o eventual comprometimento de uma chave de sessão não resulte na exposição de outros recursos do sistema, o que limita o impacto de falhas de segurança a um contexto isolado e temporalmente restrito [Tanenbaum and Van Steen 2017]. Ao descentralizar a confiança por meio de segredos dinâmicos, o Kerberos mantém a integridade dos dados e a privacidade dos usuários em ambientes de rede inerentemente inseguros [Coulouris et al. 2013].

3.4.4. Vulnerabilidades e Pontos de Falha

Apesar da robustez oferecida pelo protocolo, a centralização da confiança no Centro de Distribuição de Chaves introduz riscos estruturais significativos que devem ser considerados no projeto de sistemas seguros. O KDC constitui um ponto único de falha, de modo que a indisponibilidade deste serviço impede que qualquer usuário ou servidor estabeleça novas sessões de comunicação na rede. Em implementações de larga escala, como o Microsoft Active Directory, essa limitação é mitigada por meio da replicação de controladores de domínio, o que garante a continuidade do serviço, mas eleva a complexidade do gerenciamento de chaves sincronizadas entre os múltiplos servidores [Tanenbaum and Van Steen 2017].

A segurança do Kerberos reside na integridade física e lógica do KDC, visto que o comprometimento desta entidade central anula todas as garantias de confidencialidade e autenticidade. Caso um invasor obtenha acesso à chave mestra do serviço de concessão de tickets, ele torna-se capaz de forjar credenciais conhecidas como *Golden Tickets*. Essas credenciais fraudulentas permitem que o atacante se mascare como qualquer usuário, inclusive administradores, com tempos de expiração arbitrários, o que torna a detecção do acesso não autorizado extremamente difícil para as ferramentas de monitoramento convencionais [Neuman and Ts'o 1994].

Adicionalmente, a dependência estrita da sincronização de relógios representa uma superfície de ataque persistente. Embora o uso de janelas de tolerância e caches de repetição proteja o sistema contra capturas de pacotes em tempo real, a fragilidade do protocolo NTP pode ser explorada para manipular o tempo percebido pelas entidades da rede. Se um agente mal-intencionado conseguir desviar o relógio de um servidor de aplicação, ele poderá viabilizar o reuso de tickets que já deveriam estar expirados, o que compromete a eficácia dos mecanismos de defesa baseados em *timestamps* [Coulouris et al. 2013]. Dessa forma, a segurança do Kerberos não é uma propriedade isolada do protocolo, mas sim o resultado da integridade conjunta de toda a infraestrutura de suporte.

4. Estudo de Caso: Microsoft Active Directory

[WESLEY]

Embora o Kerberos seja um padrão aberto, sua implementação mais difundida ocorre no Microsoft Active Directory (AD), utilizado globalmente para gerenciamento de

identidades em redes corporativas. Desde o Windows 2000, o Kerberos é o protocolo de autenticação padrão, substituindo o antigo NTLM.

No AD, os Controladores de Domínio (Domain Controllers) atuam como o KDC. Ao ingressar em um domínio, computadores e usuários recebem chaves secretas que são gerenciadas centralmente pelo AD.

4.1. Single Sign-On (SSO)

A principal aplicação prática perceptível ao usuário final é o recurso de *Single Sign-On* (SSO). Em um ambiente distribuído sem Kerberos, o usuário teria que digitar sua senha cada vez que acessasse uma pasta compartilhada em um servidor diferente ou acessasse a intranet.

Com a implementação do Kerberos no AD, o processo ocorre em segundo plano:

1. O usuário faz login na estação de trabalho (autenticação junto ao AS).
2. O sistema operacional armazena o TGT na memória segura (LSASS).
3. Quando o usuário clica em uma pasta de rede, o sistema operacional detecta a necessidade de autenticação, envia o TGT ao Controlador de Domínio (TGS), obtém o ticket de serviço e autentica-se no servidor de arquivos.

Tudo isso ocorre de forma transparente, proporcionando segurança robusta sem sacrificar a usabilidade.

5. Conclusão

O protocolo Kerberos representa um marco na segurança de Sistemas Distribuídos, resolvendo o complexo problema de autenticação em redes inseguras através de criptografia simétrica e de uma arquitetura de confiança centralizada. Sua capacidade de separar as credenciais de longa duração (senhas) das credenciais de sessão (tickets) reduz drasticamente a superfície de ataque.

Contudo, o modelo apresenta desafios. O KDC torna-se um ponto único de falha e um potencial gargalo de desempenho; se o KDC estiver indisponível, ninguém consegue acessar recursos na rede. Por isso, implementações reais, como o Active Directory, exigem replicação de servidores KDC. Além disso, a dependência estrita de sincronização de relógios impõe requisitos de infraestrutura adicionais. Apesar dessas limitações, o Kerberos permanece como o padrão da indústria para autenticação segura em intranets e sistemas corporativos.

Referências

- Coulouris, G., Dollimore, J., Kindberg, T., and Blair, G. (2013). *Sistemas Distribuídos: Conceitos e Projeto*. Bookman Editora, 5 edition.
- Neuman, B. C. and Ts'o, T. (1994). Kerberos: An authentication service for computer networks. *IEEE Communications Magazine*, 32(9):33–38.
- Tanenbaum, A. S. and Van Steen, M. (2017). *Sistemas Distribuídos: Princípios e Paradigmas*. Pearson Education do Brasil, 3 edition.